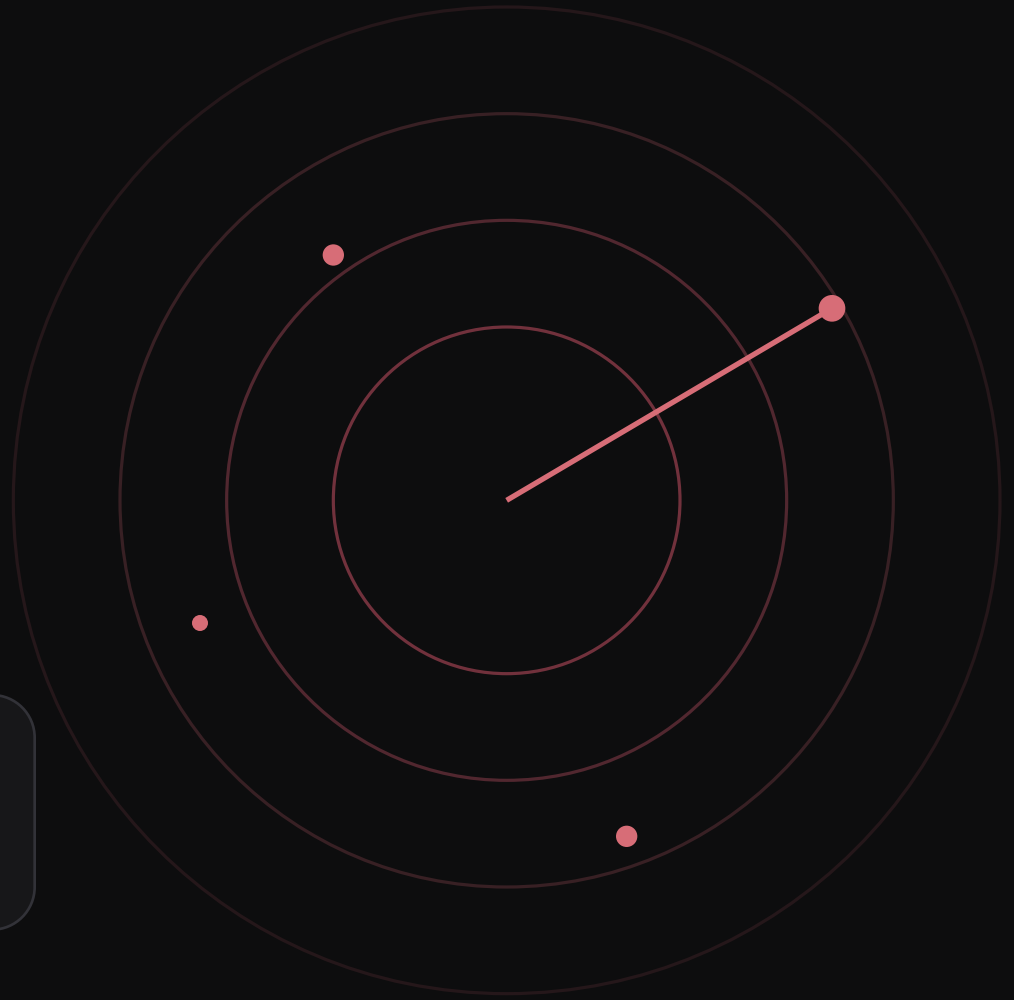
PHISH RADAR AI

SECURE ACCESS

ระบบคัดกรอง URL และเว็บไซต์เสียง

ด้วย Rule-based + Calibrated Random Forest

Chrome Extension / Web App / FastAPI / SQL Server / Qwen



แนวคิดหลัก

ตรวจจับก่อนผู้ใช้กรอก Password หรือ OTP พร้อมอธิบายเหตุผล

ออกแบบให้ทำงานแบบ local ได้ และต่อยอดสู่ระบบ AI ที่วัดผลได้

เอกสารนำเสนออาจารย์ / 24 กรกฎาคม 2026

01 / PROBLEM

ปัญหาและวัตถุประสงค์

ผู้ใช้มักตัดสินใจจากหน้าตาและข้อความลิงก์ ก่อนเห็นโดเมนปลายทางจริง

ปัญหาที่ต้องแก้

- Phishing ใช้โดเมนคล้ายแบรนด์ คำว่า login/verify และหน้าเก็บรหัสผ่านเพื่อสร้างความน่าเชื่อถือ
- การเตือนหลังผู้ใช้เข้าเว็บแล้วอาจช้าเกินไป โดยเฉพาะเมื่อมีการขอ Password หรือ OTP
- ระบบที่บล็อกอย่างเดียวอธิบายไม่ได้ ทำให้ผู้ใช้ไม่เข้าใจและเกิด False Positive ได้ง่าย

วัตถุประสงค์

01 ตรวจลิงก์และบริบทหน้าเว็บก่อนเข้าถึง

02 ผสม RuleScore กับ MLScore ด้วยค่าที่เลือกจากการทดลอง

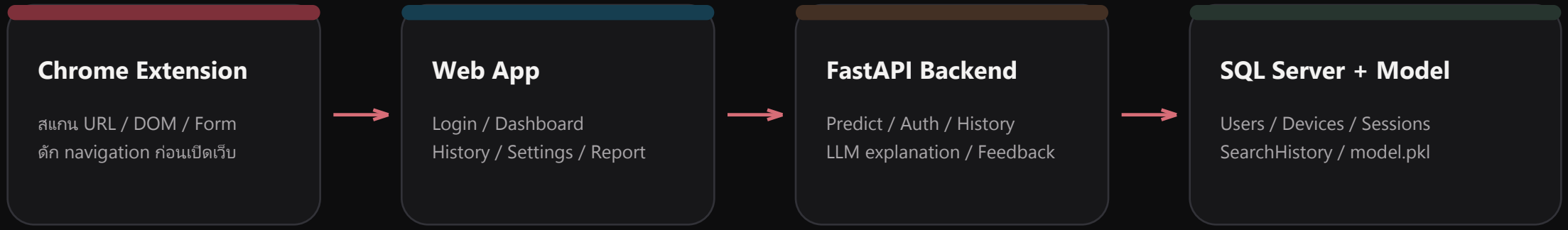
03 เก็บบัญชี อุปกรณ์ Session และประวัติอย่างปลอดภัย

04 ให้ LLM อธิบายผล แต่ไม่อนุญาตให้เปลี่ยนคำตัดสิน

02 / ARCHITECTURE

สถาปัตยกรรมระบบแบบหลายชั้น

Extension ยังตรวจแบบ local ได้เมือ Backend หรือ LLM ไม่พร้อม



เส้นทางข้อมูลทีออกแบบให้ลดความเสียหาย

Rule-based local

ใช้ได้ทันทีโดยไม่ต้องส่ง URL ออกนอกเครือง

ML local API

Random Forest ถูกโหลดจากไฟล์โมเดลใน Backend

LLM optional

สร้างคำอธิบายเท่านั้น หากไม่พร้อมใช้ข้อความสำรอง

SQL security

เก็บ PasswordHash และ TokenHash ไม่เก็บ secret ดิบ

03 / DETECTION FLOW

ตรวจจับก่อนเข้าถึง และอธิบายได้

ระบบรวมสัญญาณจาก URL หน้าเว็บ และนโยบายที่ผ่านการประเมิน

1

รับ URL / หน้าเว็บ

navigation, link, form, clipboard หรือ QR

→

2

คำนวณ RuleScore

URL structure, brand, redirect, DOM context

→

3

ขอ MLScore

calibrated probability จาก Random Forest

→

4

สร้าง FinalScore

alpha และ threshold จาก model bundle

→

5

ตอบสนอง

อนุญาต / เตือน / บันทึก และอธิบายเหตุผล

ตัวอย่างสัญญาณที่อธิบายให้ผู้ใช้เห็นได้

- HTTP บนหน้า Login
- Subdomain ซ้อน
- Brand impersonation
- Punycode / Homoglyph
- Redirect ซ่อนปลายทาง
- Password / OTP form
- ลิงก์ย่อ / ไฟล์เสียง
- ข้อความลิงก์ไม่ตรง URL

04 / DATASET

ชุดข้อมูลสมดุลและป้องกันข้อมูลรั่วไหล

ข้อมูลถูก parse เป็นข้อความเท่านั้น ระบบสร้าง Dataset ไม่เข้าเยี่ยมชม URL ใน feed

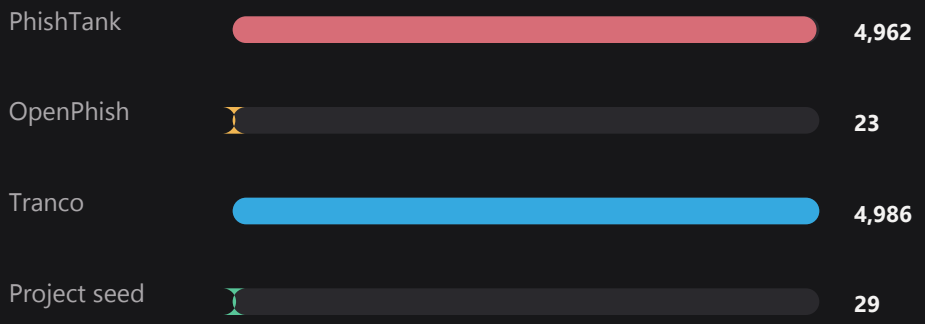
10,000
URL ทั้งหมด

5,000 / 5,000
Phishing / Legitimate

7,933
Unique hostnames

42
Random seed

แหล่งข้อมูล



หลักการเตรียมข้อมูล

- Normalize และลบ URL ซ้ำแบบ case-insensitive
- ตัด hostname ที่มี label conflict ออกจากฝั่ง legitimate
- Group ตาม hostname เพื่อไม่ให้โดเมนเดียวกันรั่วข้าม fold
- บันทึก SHA-256 ของ Dataset, feed และ analyzer เพื่อทำซ้ำได้

Cross-validation, Calibration และ Policy Search

ทุกแถวได้รับ out-of-fold probability ก่อนนำไปเลือก alpha และ threshold

A

StratifiedGroupKFold

5 outer folds
Group = hostname

→

B

Random Forest

250 trees
balanced_subsample

→

C

Sigmoid calibration

3 inner group folds
5 folds สำหรับ final model

→

D

Policy search

21 alpha x 91 threshold
รวม 1,911 candidates

กติกาเลือก Policy

กำหนด False Positive Rate ไม่เกิน 5% แล้วเลือก Recall สูงสุด

หาก Recall เท่ากัน จึงพิจารณา F1, Precision, ROC-AUC และ FPR ตามลำดับ

06 / HYBRID RISK

สูตรคะแนนไม่ได้กำหนดจากความรู้สึก

ค่า alpha และ threshold ถูกเลือกจาก out-of-fold predictions ภายใต้เพดาน FPR

FinalScore

0.40(RuleScore) + 0.60(MLScore)

แจ้งเตือนเมื่อ FinalScore >= 0.22

ค่าที่เลือก

alpha = 0.40

threshold = 0.22

RuleScore

อธิบายสัญญาณได้
และทำงาน local

→

MLScore

จับรูปแบบร่วมของ features
หลัง probability calibration

→

FinalScore

ผสมข้อดีทั้งสองฝั่ง
ด้วย policy ที่วัดผลแล้ว

→

Decision

ใช้ threshold จาก model bundle
ไม่ hard-code ในหน้าจอ

ผลการประเมินบน Out-of-fold Predictions

ผลลัพธ์นี้เป็น Cross-validation บน snapshot ปัจจุบัน ยังไม่ใช่การรับรอง production

95.09%	96.82%	95.95%	98.71%	5.00%
Precision	Recall	F1	ROC-AUC	FPR

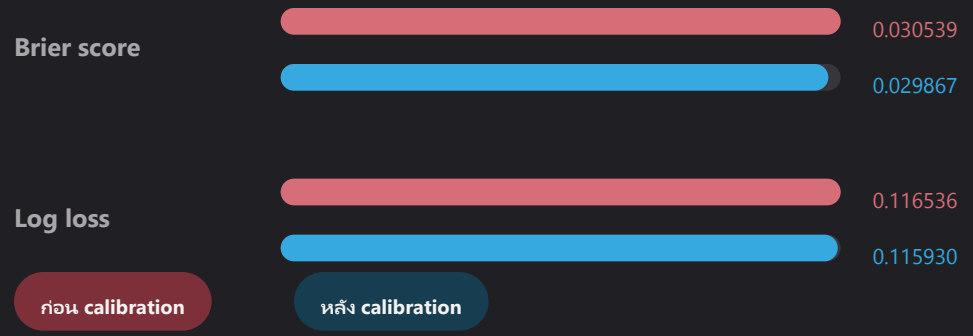
Confusion Matrix

TN 4,750	FP 250
FN 159	TP 4,841

Predicted

Actual

Probability Calibration



ระบบสมาชิกและฐานข้อมูลที่ไม่เก็บ Secret ดิบ

User และ Admin ใช้หน้า Login เดียวกัน แต่บัญชีใหม่เริ่มต้นเป็น Role = user เสมอ

auth.Users

UserID / Username / Email / PasswordHash / Role / IsActive

Password: Argon2id hash

auth.UserDevices

DeviceName / DeviceKeyHash / Trusted / Revoked / LastSeenAt

Device token: SHA-256 hash

auth.Sessions

UserID / UserDeviceID / TokenHash / ExpiresAt / RevokedAt

Browser session: HttpOnly cookie

auth.SearchHistory

URL ที่ sanitize / URLHash / Rule/ML/FinalScore / Device / CreatedAt

Default retention: 90 วัน

09 / PRIVACY

ประวัติการค้นหาแบบ Account และ Privacy Mode

ระบบแยกเส้นทางข้อมูลตามความต้องการของผู้ใช้

Account history

- ผูกข้อมูลกับ UserID และ UserDeviceID จาก Session
- ตัด credentials, query string และ fragment ก่อนจัดเก็บ URL
- เก็บ SHA-256 ของ URL ต้นฉบับเพื่อ correlation
- เก็บ RuleScore, MLScore, FinalScore, alpha, threshold และ label
- ผู้ใช้ล้างประวัติหรือส่งออก JSON/CSV ได้

Privacy Mode

- วิเคราะห์ใน Browser และไม่ส่ง URL ไป Backend/LLM
- เก็บประวัติเฉพาะ localStorage ภายใต้บัญชีบนเครื่องนั้น
- ปิด Qwen explanation และ ML cloud assist โดยอัตโนมัติ
- Rule-based protection และคำเตือน local ยังทำงานต่อ

หลักการ

ผู้ใช้เป็นผู้เลือกระดับการส่งข้อมูล ไม่ใช่ระบบเลือกแทน

Qwen เป็นผู้ช่วยอธิบาย ไม่ใช่ผู้ตัดสิน

FinalScore และการบล็อกต้องให้ผลเดิม แม้ LLM ปิดหรือใช้งานไม่ได้

ค่าเริ่มต้น

Qwen3:4b ผ่าน Ollama

ทำงาน local ลดการส่งข้อมูลออกนอกเครื่อง
และยังใช้ข้อความ fallback ได้เมื่อโมเดลไม่พร้อม

ตัวเลือกเปรียบเทียบ

OpenAI API (optional)

เหมาะสำหรับเปรียบเทียบคุณภาพและ latency
แต่ต้องใช้อินเทอร์เน็ต ค่า API และนโยบายข้อมูลที่ชัดเจน

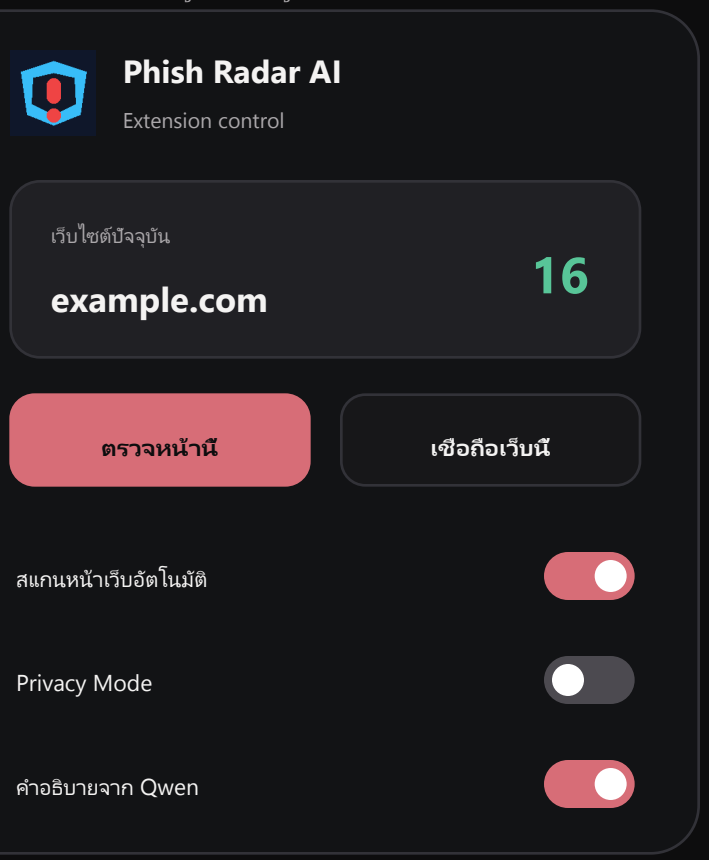
Benchmark ที่ต้องทำต่อ

- คุณภาพคำอธิบาย 1-5
- JSON/schema pass rate
- Hallucination rate
- Latency p50/p95
- Cloud cost หรือ RAM/VRAM

สถานะปัจจุบัน: มีแผนทดลองแล้ว แต่ยังไม่มีผล benchmark บนเครื่องนี้

สิ่งที่พัฒนาเสร็จและลำดับการสาธิต

รายการจากอาจารย์ถูกนำมาผูกกับโค้ดและเอกสารจริงในโปรเจกต์



สถานะงานตามรายการ

01	แหล่งอ้างอิงและวิธีคำนวณความเสี่ยง	เสร็จ
02	User Login และการเก็บข้อมูลผู้ใช้	เสร็จ
03	ประวัติการค้นหาแยกตาม User/Device	เสร็จ
04	คำสั่งเริ่มระบบด้วย Git Bash	เสร็จ
05	เปรียบเทียบ LLM และตั้ง Qwen เป็นค่าเริ่มต้น	ออกแบบแล้ว

คำสั่ง Demo: `./migrate-db.sh` แล้ว `./start-demo.sh`

ข้อจำกัดและงานที่ควรทำต่อ

เน้นลดช่องว่างระหว่างผล Cross-validation กับการใช้งานจริง

ข้อจำกัดปัจจุบัน

- Dataset snapshot เดียวอาจไม่สะท้อนแคมเปญ phishing ในอนาคต
- ยังไม่มี time-split holdout และ traffic จริงที่แยกจากการเลือก policy
- Rule-based และ URL features อาจพลาดหน้าเว็บที่เลียนแบบด้วยภาพหรือ DOM ขั้นสูง
- LLM comparison ยังไม่มีผล benchmark จาก prompt และเครื่องเดียวกัน
- Admin role ยังควรมี API และ audit log แทนการปรับผ่าน SQL โดยตรง

ลำดับพัฒนาต่อ

1. **External/time-split evaluation**
   ยืนยันค่า alpha และ threshold กับข้อมูลใหม่
2. **Drift monitoring + retraining**
   ติดตาม FPR/Recall และ version Dataset/Model
3. **LLM benchmark**
   วัดคุณภาพ Hallucination และ latency อย่างยุติธรรม
4. **Admin API + audit log**
   จัดการ Role, Account และเหตุการณ์สำคัญ
5. **Controlled deployment**
   HTTPS, secret management, backup และ monitoring

13 / DEFENSE NOTES

คำถามทีคาดว่าจะได้รับ

คำตอบสั้นควรผูกกับหลักฐานในผลทดลองและข้อจำกัดของระบบ

ทำไม alpha = 0.4?

ทดลอง 21 ค่าและ 91 thresholds บน out-of-fold predictions แล้วเลือก Recall สูงสุดภายใต้ FPR <= 5%

ทำไมต้อง Calibration?

predict_proba ดิบไม่จำเป็นต้องเป็นความน่าจะเป็นทีเชือถือได้ จึงปรับด้วย sigmoid และตรวจ Brier/Log loss

ระบบเก็บรหัสผ่านหรือไม่?

ไม่เก็บรหัสผ่านจริง เก็บ Argon2id PasswordHash และเก็บ Session/Device token เฉพาะ SHA-256 hash

Qwen เป็นตัวตัดสิน Phishing หรือไม่?

ไม่ใช่ LLM มีหน้าทีอธิบาย RuleScore/MLScore เท่านัน ปิด LLM แล้ว FinalScore ต้องไม่เปลียน

ผลนีพร้อมใช้ Production หรือยัง?

ยัง ต้องเพิม time-split holdout, traffic จริง, drift monitoring, audit log และ deployment controls

ถ้า Backend ล่มจะเกิดอะไรขึน?

Extension ยังใช้ Rule-based local และคำเตือนแบบ offline ได้ แต่ ML, Login/History และ LLM จะไม่พร้อม

14 / REFERENCES

แหล่งข้อมูลและงานอ้างอิงหลัก

รายละเอียดการทดลองทั้งหมดอยู่ใน docs/RISK_MODEL_METHODOLOGY_TH.md

Le Pochat, V. et al. (2019)

Tranco: A Research-Oriented Top Sites Ranking Hardened Against Manipulation. NDSS. https://doi.org/10.14722/ndss.2019.23386

Niculescu-Mizil, A. and Caruana, R. (2005)

Predicting Good Probabilities with Supervised Learning. ICML. https://doi.org/10.1145/1102351.1102430

Saito, T. and Rehmsmeier, M. (2015)

The Precision-Recall Plot Is More Informative than the ROC Plot. PLOS ONE. https://doi.org/10.1371/journal.pone.0118432

Dataset feeds

PhishTank verified online feed; OpenPhish Community Feed; Tranco top-sites list. Snapshot hashes are recorded in training_urls.manifest.json

Software documentation

scikit-learn: StratifiedGroupKFold, CalibratedClassifierCV and probability calibration documentation.

Project evidence

risk_model_evaluation.json, training_urls.manifest.json, SQL migrations 001-003, backend tests and project validation scripts.